

Report ID	CLD-IR-0002	Related Ticket	CLD-0002 - Targeted Credential Phishing Impersonating Cloudora HR
Report Title	Targeted Payroll Credential Phishing Campaign and Account Compromise Investigation		
Operational Lead	SOC Lead Analyst (Simulated Engagement)	Date of Report (UTC)	2026-08-25
Incident Severity	P1 - CRITICAL (Active Cloud Directory Compromise / Data Exposure)	Lifecycle State	CONTAINED & ERADICATED (Monitoring Ongoing)
Classification	CONFIDENTIAL — Internal & Client Distribution Only		

1. Executive Summary

On 25 August 2026, an external threat actor launched a coordinated, payroll-themed credential phishing campaign targeting 40 employees at Cloudora. The adversary distributed two operational variants: one forging Cloudora’s legitimate internal domain (`payroll@cloudora.io`) which failed all transport authentication checks, and a secondary variant from a deceptive lookalike domain (`cloudora-hr-portal.example`) configured with valid cryptographic authentication. Telemetry confirmed that six employees clicked the malicious hyperlinks, and two individuals submitted their corporate credentials into the harvesting portal.

Within hours of credential submission, the attacker successfully authenticated to both compromised accounts from a hosted endpoint located in Amsterdam, accessing cloud email and document repositories. Following an initial report by an observant employee, the Security Operations Center (SOC) initiated rapid containment: terminating all active session tokens, forcing enterprise password resets, enforcing multi-factor authentication, blacklisting all adversarial network infrastructure and domains, and executing a zero-hour mailbox purge across the organization. Forensics confirmed that the attacker did not execute unauthorized financial modifications or establish persistence. Precautionary credential rotations and awareness notifications have been initiated for all impacted and near-miss recipients.

2. Incident Timeline

All timestamps recorded in UTC. Log Sources: Exchange Online Message Trace (`CloudoraMsgTrace_CL`), Entra ID Sign-In Logs (`CloudoraSignIn_CL`), and RFC 822 Email Submissions.

Time (UTC)	Log Artifact	Categorization	Operational Description & Supporting Evidence
06:58:00	CloudoraMsgTrace_CL	Legitimate Traffic	Authorized corporate newsletter distributed via Mailchimp (<code>news@cloudora.io</code>); reported as suspect, reviewed, and cleared as false positive.
08:04–08:20	CloudoraMsgTrace_CL	Adversary Ingress	Variant A Wave 1 ingress from <code>198.18.44.10</code> mimicking <code>payroll@cloudora.io</code> . EOP auto-quarantines 4 messages; 16 reach target inboxes.
08:35–08:50	CloudoraMsgTrace_CL	Adversary Ingress	Variant A Wave 2 (<code>198.18.44.23</code>) and Variant B (<code>198.18.51.7</code> , <code>cloudora-hr-portal.example</code>) dispatched across the organization.

Time (UTC)	Log Artifact	Categorization	Operational Description & Supporting Evidence
08:39:03	CloudoraMsgTrace_CL	User Interaction	<code>seth.lane</code> opens Variant A URL; connection drops prior to data submission (<code>CredentialsSubmitted = No</code>).
08:47:12	CloudoraMsgTrace_CL	Credential Theft	<code>freya.lynn</code> accesses Variant A hyperlink and inputs authentication credentials (<code>CredentialsSubmitted = Yes</code>).
09:05:44	CloudoraMsgTrace_CL	Credential Theft	<code>ryan.boyd</code> accesses Variant B hyperlink and inputs authentication credentials (<code>CredentialsSubmitted = Yes</code>).
09:11:00	SecOps Ticketing	Case Inception	Suspicious communication forwarded by <code>james.holt</code> ; Ticket <code>CLD-0002</code> generated; triage initiated.
09:58:00	CloudoraMsgTrace_CL	User Interaction	<code>hugo.marsh</code> opens phishing link; no data transmitted (<code>CredentialsSubmitted = No</code>).
10:12:00	CloudoraMsgTrace_CL	User Interaction	<code>chloe.price</code> opens phishing link; no data transmitted (<code>CredentialsSubmitted = No</code>).
10:34:20	CloudoraSignIn_CL	Account Breach	Attacker authenticates as <code>freya.lynn</code> from Amsterdam IP <code>198.18.7.200</code> via Chrome/Win11 (T1078.004). Impossible travel vs Manchester.
10:36–10:41	CloudoraSignIn_CL	Unauthorized Access	Attacker accesses Outlook Web App (10:36) and SharePoint Online (10:41) under <code>freya.lynn</code> identity.
11:47:00	CloudoraMsgTrace_CL	User Interaction	<code>dina.said</code> opens phishing link; no data transmitted (<code>CredentialsSubmitted = No</code>).
13:22:05	CloudoraSignIn_CL	Account Breach	Attacker authenticates as <code>ryan.boyd</code> from Amsterdam IP <code>198.18.7.200</code> via Chrome/Win11 (T1078.004).
13:25:33	CloudoraSignIn_CL	Unauthorized Access	Attacker accesses Outlook Web App resources under <code>ryan.boyd</code> identity.
14:00:00	SOC Active Response	Containment	SOC revokes active sessions, forces credential updates, blacklists IPs/domains, and purges mailboxes.

3. Investigation Findings

Finding 1 — Coordinated Impersonation Campaign Dispatched to Enterprise: Telemetry verifies delivery attempts of 40 phishing objects themed around urgent payroll compliance ("*Payroll update: action required before 5pm*" and "*Action required: confirm your August payroll details*"). 36 targets received messages directly into primary inboxes; 4 were shielded via perimeter quarantine mechanisms.

Finding 2 — Exploitation of Asymmetric Mail Authentication Controls: Threat actors relied on two delivery methodologies. Variant A executed direct display-header spoofing (`payroll@cloudora.io`), triggering explicit `compauth=fail` states. Variant B used an unauthorized typosquatted infrastructure (`cloudora-hr-portal.example`) with configured SPF/DKIM keys, allowing passing authentication headers despite host illegitimacy. Passing authentication only validates domain alignment, not operational safety.

Finding 3 — Cloud Directory Compromise via Stolen Account Credentials: Two enterprise users (`freya.lynn` and `ryan.boyd`) submitted corporate credentials into hostile landing pages. The adversary subsequently initiated remote

interactive sign-ins from an Amsterdam ingress point (198.18.7.200), establishing impossible-travel anomalies and accessing proprietary workloads (Outlook Web, SharePoint).

Finding 4 — Peripheral User Exposure Without Credential Extraction: Four additional employees (seth.lane , chloe.price , hugo.marsh , and dina.said) navigated to the harvesting infrastructure but disconnected without data submission (CredentialsSubmitted = No), with no subsequent unauthorized authentications observed.

Finding 5 — Segmented Enterprise Exposure Profile: 30 recipients received malicious correspondence without link interaction (near-miss cohort), while 4 users were shielded via automatic EOP quarantine filtering.

Finding 6 — Invalidation of Reported False-Positive Newsletter: A forwarded internal marketing item ("Cloudora Monthly") was assessed. The artifact exhibited valid DKIM cryptographic alignment referencing cloudora.io , verified DMARC compliance, and linked strictly to verified list-management nodes, eliminating it from incident scope.

4. Indicators of Compromise (IOCs)

Category	Indicator Value (Defanged)	Analytical Attribution & Context
Domain	cloudora-hr-portal[.]example	Typosquatted landing domain utilized for infrastructure and harvesting.
Hostname	login.cloudora-hr-portal[.]example	Harvest endpoint used across Variant B distribution.
Hostname	mail.cloudora-hr-portal[.]example	Mail exchange relay node referenced in delivery headers.
URL	hxxps://cloudora-hr-portal[.]example/payroll/login	Variant A harvesting URI.
URL	hxxps://login.cloudora-hr-portal[.]example/verify	Variant B harvesting URI.
IPv4 Address	198.18.44.10	Variant A Wave 1 outbound relay / host node.
IPv4 Address	198.18.44.23	Variant A Wave 2 outbound relay / host node.
IPv4 Address	198.18.51.7	Variant B outbound distribution relay.
IPv4 Address	198.18.7.200	Adversary egress host (Amsterdam, NL); utilized during cloud sign-in compromise.
Sender ID	payroll@cloudora.io	Spoofed envelope sender address (Variant A).
Sender ID	payroll@cloudora-hr-portal.example	Typosquatted sender address (Variant B).
Subject	Payroll update: action required before 5pm	Phishing lure subject header (Variant A).
Subject	Action required: confirm your August payroll details	Phishing lure subject header (Variant B).

5. MITRE ATT&CK Matrix Mapping

Tactical Objective	Technique ID	Technique Designation	Log Corroboration & Context
Initial Access	T1566.002	Phishing: Spearphishing Link	Transmission of tailored payroll lure emails directing targets to credential harvesting portals (Finding 1 & 2).
Credential Access	T1598.003	Spearphishing Link for Information	Deployment of spoofed HR login forms capturing enterprise passwords (Finding 3).

Tactical Objective	Technique ID	Technique Designation	Log Corroboration & Context
Initial Access / Persistence	T1078.004	Valid Accounts: Cloud Accounts	Authentication against tenant resources (Exchange Online/SharePoint) via stolen employee credentials (Finding 3).
Supporting Stage	T1583.001	Acquire Infrastructure: Domains	Registration of lookalike entity <code>cloudora-hr-portal.example</code> prior to operation launch.

6. Environmental Scope

Total Targets (40 Accounts)
Confirmed Compromised (2 Accounts)
— <code>freya.lynn@cloudora.io</code> (Clicked, Submitted Credentials, Attacker Login at 10:34 UTC)
— <code>ryan.boyd@cloudora.io</code> (Clicked, Submitted Credentials, Attacker Login at 13:22 UTC)
Elevated Risk / Clickers (4 Accounts)
— <code>seth.lane</code> , <code>chloe.price</code> , <code>hugo.marsh</code> , <code>dina.said</code> (Clicked link, No credentials submitted, No anomalous sign-ins)
Targeted / Delivered Non-Clickers (30 Accounts)
— 30 users received email in inbox without interacting (Near-miss awareness group)
Perimeter Defended / Quarantined (4 Accounts)
— <code>emma.hayes</code> , <code>maya.chen</code> , <code>nina.cole</code> , <code>ruth.dean</code> (All copies quarantined by EOP)
Cleared False Positives (1 Item)
— "Cloudora Monthly" Newsletter via Mailchimp (<code>news@cloudora.io</code> - Verified DKIM/DMARC)

7. Remediation & Countermeasure Actions

Order	Operational Countermeasure	Target Entity	Strategic Rationale & Verification
01. Immediate	Invalidation of Active Refresh Tokens & Web Sessions	<code>freya.lynn</code> <code>ryan.boyd</code>	Terminates active adversary persistence instantly, preventing concurrent session continuity.
02. Immediate	Directory Credential Reset	<code>freya.lynn</code> <code>ryan.boyd</code>	Voids stolen credentials once sessions have been terminated.
03. Containment	MFA Re-Registration & Policy Enforcement	<code>freya.lynn</code> <code>ryan.boyd</code>	Enforces strong challenge factors, mitigating password-only replay avenues.
04. Perimeter	Edge & Proxy Infrastructure Blacklisting	<code>198.18.44.10</code> , <code>.23</code> <code>198.18.51.7</code> , <code>198.18.7.200</code> <code>*.cloudora-hr-portal.example</code>	Isolates all identified delivery relays, command-and-control access nodes, and harvesting pages.
05. Cleanup	Zero-Hour Mail Store Purge (ZAP / Soft Delete)	Enterprise Mailbox Fleet	Removes unread or dormant attack artifacts across all 36 delivery destinations.
06. Verification	Forensic Re-Query Analysis	Tenant Authentication Logs	Proves total cessation of traffic from hostile nodes post-14:00 UTC.

8. Strategic Recommendations

Tactical Wins (Immediate Execution)

- **Targeted Safeguards for Vulnerable Users:** Issue password resets for the four individuals who opened links, and dispatch the non-punitive incident notification to the 30 near-miss recipients.
- **Strict DMARC Policy Elevation:** Shift Cloudora's public DMARC record from monitoring (`p=none/quarantine`) to `p=reject` , stopping spoofed variants like Variant A at upstream mail gateways.
- **Automated SIEM Analytic Rule Deployment:** Implement the behavioral detection rule linking external web click events to subsequent cross-border sign-in events within short windows.

Long-Term Strategic Safeguards

- **Tenant-Wide Phishing-Resistant MFA:** Transition standard identity profiles to FIDO2 WebAuthn keys or Microsoft Authenticator number-matching policies, mitigating harvested-credential replay attacks.
- **Mail Gateway Typosquatting Inspections:** Establish content-filtering rules flagging inbound mail claiming internal brand affiliations from newly registered domains (less than 30 days old).
- **Automated Incident Response Playbooks:** Integrate automated SOAR workflows to kill user sessions and ZAP mailboxes immediately upon high-fidelity threat correlation.

9. Lessons Learned

- **User Reporting Velocity:** Detection and response was accelerated by rapid user reporting from James Holt. Maintaining straightforward, frictionless reporting processes directly shortens detection timeframes.
- **Pivoting Beyond the First Victim:** Limiting scope to the initial reported user would have left Ryan Boyd's compromised session active. Pivoting on the adversary ingress address (`198.18.7.200`) was key to uncovering the full breach footprint.
- **Authentication Nuance:** A passing SPF/DKIM check does not equate to benign intent. Variant B demonstrated that an adversary can register custom infrastructure and pass all authentication hurdles cleanly. Analysts must verify which domain is authenticating, not just the pass/fail label.
- **Detection Engineering Gap:** The 1-to-4 hour window between link interaction and unauthorized access underlines the need for automated click-to-login correlation rules, reducing reliance on manual triage.

End of Incident Report CLD-IR-0002. Fictional client scenario (Cloudora) — Training artefact for MyFirstHack Cybersecurity.